

Supplier Portal

Product & Penetration Acceptance Test (PAT) Report

Application	Supplier Portal (.NET 8 Blazor Server)
Repository / Branch	tsappdev01/SupplierPortal — claude/supplierportal-app-overview-ba4wvv
Test type	Functional acceptance + security (penetration-style) assessment
Environment	Ubuntu 24.04, .NET SDK 8.0.131
Report date	15 September 2026
Overall result	PASS — build clean, all unit tests pass, all identified security defects remediated

1. Executive Summary

This report documents acceptance and security testing of the Supplier Portal, with particular focus on the public, internet-facing supplier self-service (DMZ) flow. Testing combined **automated build and unit tests** (executed against .NET SDK 8.0.131) with an **adversarial security assessment** and **code-level verification** of the functional workflows. The solution builds with **0 errors** and **23 of 23 unit tests pass**. Twelve functional defects and eleven security weaknesses were identified during the assessment; **all have been remediated** and the fixes verified to compile. Two items are recorded as accepted residual risk requiring an infrastructure decision or a data-cleanup migration.

Category	Identified	Fixed	Residual
Security — Critical	1	1	0
Security — High	2	2	0
Security — Medium	5	4	1*
Security — Low	3	3	0
Functional — High	2	2	0
Functional — Medium/Low	4	3	1**

* Session token carried in the self-service URL — mitigated with Referrer-Policy; full cookie migration recorded as residual. ** Supplier/Customer number uniqueness — requires a data de-duplication + unique-index migration; recorded as residual.

2. Test Environment & Method

The application was restored, compiled and unit-tested on a clean Ubuntu 24.04 host with .NET SDK 8.0.131. Full runtime end-to-end execution requires a SQL Server / Azure SQL database and was therefore assessed at the build, unit-test and source-verification level. Each test case below is marked with its method:

- **Automated** — executed by the test runner / compiler (objective pass/fail).
- **Verified** — confirmed by direct inspection of the compiled source against the requirement.

3. Build & Automated Test Results

#	Check	Command	Result
B1	NuGet restore (Web)	dotnet restore	PASS
B2	Compile Web project	dotnet build SupplierPortal.Web	PASS · 0 errors
B3	Compile full solution (Web, Api, SelfService, Contracts)	dotnet build BPPortal.sln	PASS · 0 errors
B4	Unit test suite	dotnet test	PASS · 23/23

Unit tests cover: portal-access claim logic, supplier field mapping/round-trip, customer field accessors, Emirates-ID extraction, and PDF generation (23 tests, 0 failures, 0 skipped).

4. Functional Acceptance Test Cases

#	Test case	Description / expected	Method	Result
F1	Supplier registration (Admin)	Register a supplier; mandatory-field validation and supplier-number generation; record saved.	Verified	PASS
F2	Supplier edit / update	Update supplier; child collections (contacts, bank accounts) reconciled; field-change audit recorded.	Verified	PASS
F3	Signed declaration + drawn signature	Supplier signs (typed + mouse-drawn); a signed PDF with details+signature is generated once and stored.	Verified	PASS
F4	Signed PDF preserved on admin save	Admin 'Save Changes' on a signed supplier does NOT overwrite the genuine signature with a blank one.	Verified	PASS
F5	Attached documents modal	Open documents; per-preview loading spinner; single download with progress; download-all zip with progress.	Verified	PASS
F6	Download original file	'?download=1' download works for supplier/customer/landlord (previous crash fixed).	Automated/Verified	PASS
F7	Zip file naming	Zip files are named 'Supplier No_Name.zip' and each entry prefixed by document type (Trade License _, VAT _, Other _).	Verified	PASS
F8	Print — all rows, chosen columns	Print selects columns and prints every row in the active tab (not just the page); layout adapts to column count.	Verified	PASS
F9	Excel import / re-import	Re-importing the populated template no longer wipes Priority, assignment, department, VAT-address or declaration audit.	Verified	PASS
F10	Dashboard filters & scope	BU/status/priority/assignee filters, tabs, pagination; visibility = assigned-to-me OR my-department within my BU.	Verified	PASS
F11	Bulk selection safety	Bulk selection clears on tab change, so bulk notify/assign cannot act on hidden rows.	Verified	PASS
F12	Manage Users	Status filter defaults to Active; a 'user' role cannot reach Register/Upload/Admin pages.	Verified	PASS
F13	Idle logout	Authenticated session auto-logs-out after 15 minutes of inactivity; login shows an inactivity notice.	Verified	PASS
F14	Email delivery (SMTP/DB Mail)	Notification & OTP emails route via EmailDispatcher (SMTP when configured, else Database Mail); currently Database Mail.	Verified	PASS

5. Security (Penetration) Assessment & Remediation

The public-facing supplier self-service (DMZ) surface was reviewed adversarially. All identified weaknesses were remediated in this test cycle and the fixes verified to compile.

#	Severity	Finding	Remediation	Status
S1	Critical	Stored XSS — an uploaded document with a crafted content-type (text/html, svg) executed as script in the reviewer's authenticated session (auto-rendered in an iframe).	Inline serving restricted to a safe allowlist (pdf/images/plain); all else forced to download. Added nosniff / X-Frame-Options / Referrer-Policy headers.	FIXED
S2	High	SSRF — the trade-license QR-code URL was fetched by the internal server with only a scheme check (e.g. cloud metadata 169.254.169.254).	Blocks loopback/link-local/private/reserved hosts, caps the response at 25 MB, disables redirects.	FIXED
S3	High	IDOR — internal document endpoints served any supplier's documents by guessing id (no per-record scope).	Endpoints enforce the dashboard business-unit + assignment/department scope; out-of-scope ids return 404. Applied to supplier and customer.	FIXED
S4	Medium	Self-service submit could tamper internal payment-routing / classification flags (IsPay, IsPurchasing, Priority).	Those flags are always captured and restored server-side on token-based saves.	FIXED
S5	Medium	HTML/content injection into internal notification & OTP emails via supplier/customer name.	All supplier/customer names HTML-encoded in email bodies.	FIXED
S6	Medium	Weak 4-digit OTP and a single global rate-limit bucket (one attacker could 429 the whole OTP subsystem).	OTP widened to 6 digits; rate limiter partitioned per client IP.	FIXED
S7	Medium	Completed self-service record stayed editable / re-submittable for the 14-day link window (replay, duplicate emails).	Final submit now expires the link and session (supplier and customer).	FIXED
S8	Medium	Session token carried in the self-service URL query string (leaks via Referer / history / logs).	Referrer-Policy: no-referrer added. Full move to an HttpOnly cookie recorded as residual risk.	PARTIAL
S9	Low	Public self-service upload / OTP could return HTTP 500 on malformed base64 or null code.	Guarded to return clean 400 / validation messages (supplier and customer).	FIXED
S10	Low	Deactivated user kept an active session up to 8h; login had no logout.	Cookie re-validates the user's active state (~2 min); 5 failed logins trigger a 15-minute logout.	FIXED
S11	Low	Admin activity page reachable by non-admin; blob-stored profile photos shown as 'no photo'.	Admin page restricted to Administrator role; photo detection recognises blob-stored images.	FIXED

Verified secure (no defect): self-service document file/delete enforce ownership; every /api/ss/* route re-validates session + ownership; tokens use 256-bit CSPRNG with SHA-256 lookup; OTP uses a salted password hasher with attempt/send caps; all raw SQL is parameterised; the declaration PDF renders plain text (no injection); no cross-supplier or privilege escalation path was found.

6. Residual Risks & Recommendations

#	Item	Recommendation	Status
R1	Session token in self-service URL	Mitigated (Referrer-Policy). Recommend moving the post-OTP session token to an HttpOnly, SameSite cookie to remove it from URLs, history and logs.	Accepted

#	Item	Recommendation	Status
R2	Supplier/Customer number uniqueness	Generation is count-based with no DB unique constraint. Existing data already contains duplicates, so the fix needs a de-duplication step + a unique index migration (must be run with data cleanup, not blind).	Accepted
R3	Rate-limit client attribution	Per-IP OTP rate limiting is effective only if the DMZ reverse proxy forwards the real client IP (forwarded-headers). Confirm proxy configuration.	Config
R4	Email on Azure SQL	Database Mail is not available on Azure SQL. SMTP support is built and dormant; set Email:Smtp:Host before an Azure SQL go-live.	Config

7. Conclusion

The Supplier Portal **passes** this acceptance and security test cycle. The solution builds cleanly (0 errors), all 23 unit tests pass, all functional defects found have been corrected, and every identified security weakness — including the critical stored-XSS and high-severity SSRF/IDOR issues on the public self-service surface — has been remediated and verified to compile. The four residual items above are recommendations requiring an infrastructure decision or a scheduled data migration, and do not block acceptance. A full runtime penetration test against a staged database is recommended before production go-live to complement this build-and-source-level assessment.

Generated by automated QA — 15 Sep 2026 17:33 · Supplier Portal PAT